PROJECT: BUILD A SECURITY MONITORING SYSTEM AWS

... By Pallavi Khadse

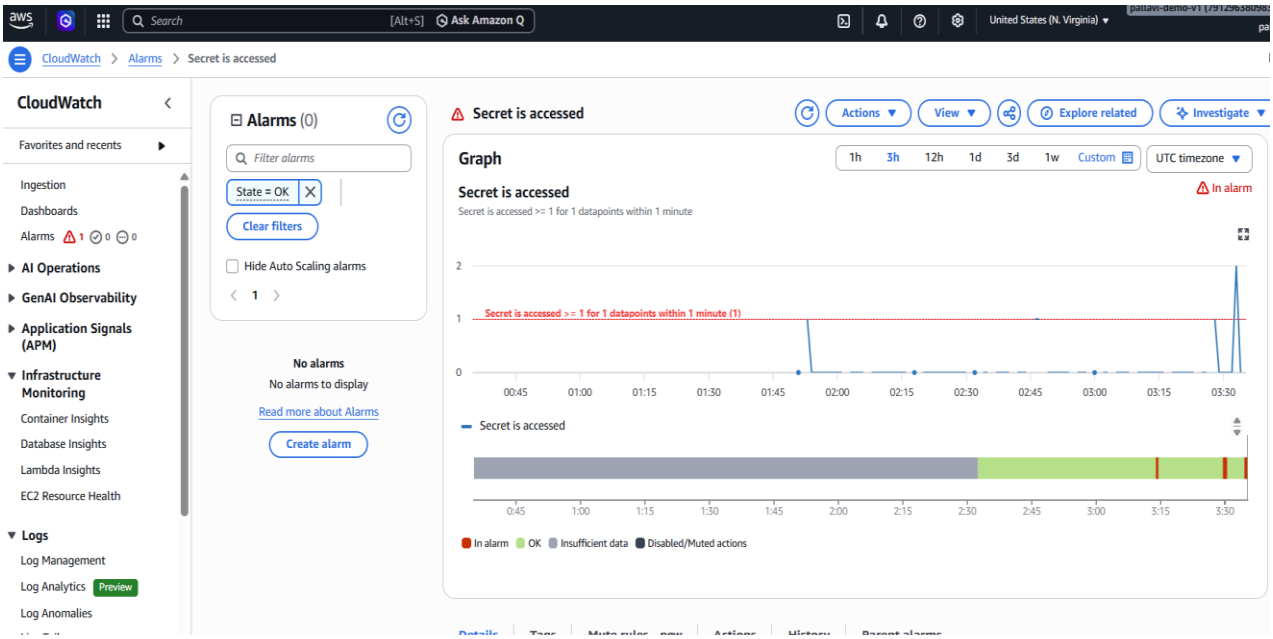

Fig. 1: CloudWatch alarm in its 'in alarm' state

Introducing Today's Project!

In this project, I will demonstrate "a Security Monitoring System and SNS alerts on email" on AWS.

Following are the steps taken:

1. Set up AWS CloudTrail to track secret access events.
2. Use AWS CloudWatch to log access attempts and trigger notifications.
3. Create SNS alerts to get notified when your secrets are accessed.
4. Build a second notification system and compare which approach delivers better security alerts.

I'm doing this project to learn various AWS services such as IAM user, Secrets Manager, CloudTrail Monitoring, S3, Logging, CloudWatch Alarm, SNS, AWS CLI, etc.

Create a Secret

Secrets Manager is an AWS service to store, rotate, monitor, and control access to secrets such as database credentials, API keys, and OAuth tokens.
To set up for my project, I created a secret called "MySecretInfo" that contains Secret key-value pair.

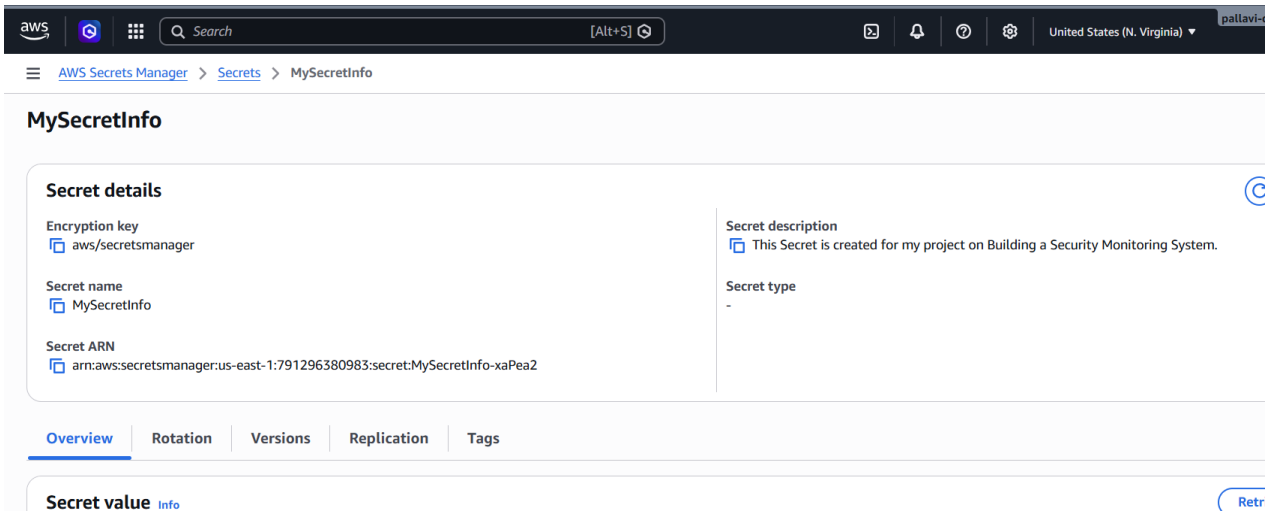

Fig.2: Secret's details page_AWS Secrets Manager

Set Up CloudTrail

CloudTrail is a monitoring service by AWS. I set up a trail to record events that happened in our AWS account, like creating resources, updating a name or setting, and accessing secrets in Secrets Manager.

AWS CloudTrail tracks Management Events (resource configuration), Data Events (resource-level actions), Insights Events (unusual API patterns), and Network activiy events. AWS CloudTrail logs API activities as Read-only (fetching data/listing resources) or Read-write (creating, modifying, or deleting resources).

Read vs Write Activity

Read activities fetch information without changing resources, while Write activities create, modify, or delete resources.

Read Activities: Operations that list, describe, or view data (e.g., DescribeInstances in EC2, ListBuckets in S3). They do not alter your infrastructure.

Write Activities: Operations that modify your environment (e.g., RunInstances in EC2, PutObject in S3, DeleteUser in IAM). They change your infrastructure or data state.

Verifying CloudTrail

I retrieved the secret in two ways:
1. through AWS Secrets Manager and,
2. using AWS CLI.

Fig. 3: Retrieving the secret using the AWS CLI

CloudWatch Metrics

CloudWatch Logs centralizes log data from AWS resources and applications to monitor, troubleshoot, and store log files.
It is important for Monitoring Centralized Storage: Collects logs from EC2, Lambda, CloudTrail, and applications in one place. Real-Time Monitoring: Tracks errors and metrics instantly using specific search patterns.

Automated Alerts: Triggers CloudWatch Alarms to notify teams when log errors spike.

Long-Term Retention: Stores historical log data securely for compliance and future analysis. Deep Analysis: Runs fast, SQL-like queries using CloudWatch Logs Insights to find issues.

CloudTrail stores historical records of who did what in your account for auditing, while CloudWatch stores operational data and application logs for real-time monitoring and alerting.

Key Differences:
Primary Purpose: CloudTrail is for security, compliance, and governance auditing. CloudWatch is for performance, application monitoring, and operational health.

Data Source: CloudTrail only records AWS API activity and user actions. CloudWatch collects system metrics, application logs, and OS-level data.

Analysis Speed: CloudTrail relies on Athena or external tools for slow, historical queries. CloudWatch provides real-time log streaming and fast, interactive querying.

Alerting Capabilities: CloudTrail does not have built-in alerting. CloudWatch features native, real-time alarms and metric filters.

Retention: CloudTrail automatically keeps a 90-day event history for free. CloudWatch logs require you to explicitly configure custom retention periods.

Metric value is what gets recorded when our filter spots a match in the logs. We're setting it to 1 so that each time someone accesses our secret, the counter increases by exactly

one. Default value is what gets recorded when our filter doesn't find any matches during a given time period. We're setting it to 0 so that time periods with no secret access show up as zero on our charts, rather than not showing up at all. This gives us a complete picture - we can see both when access happened AND when it didn't.

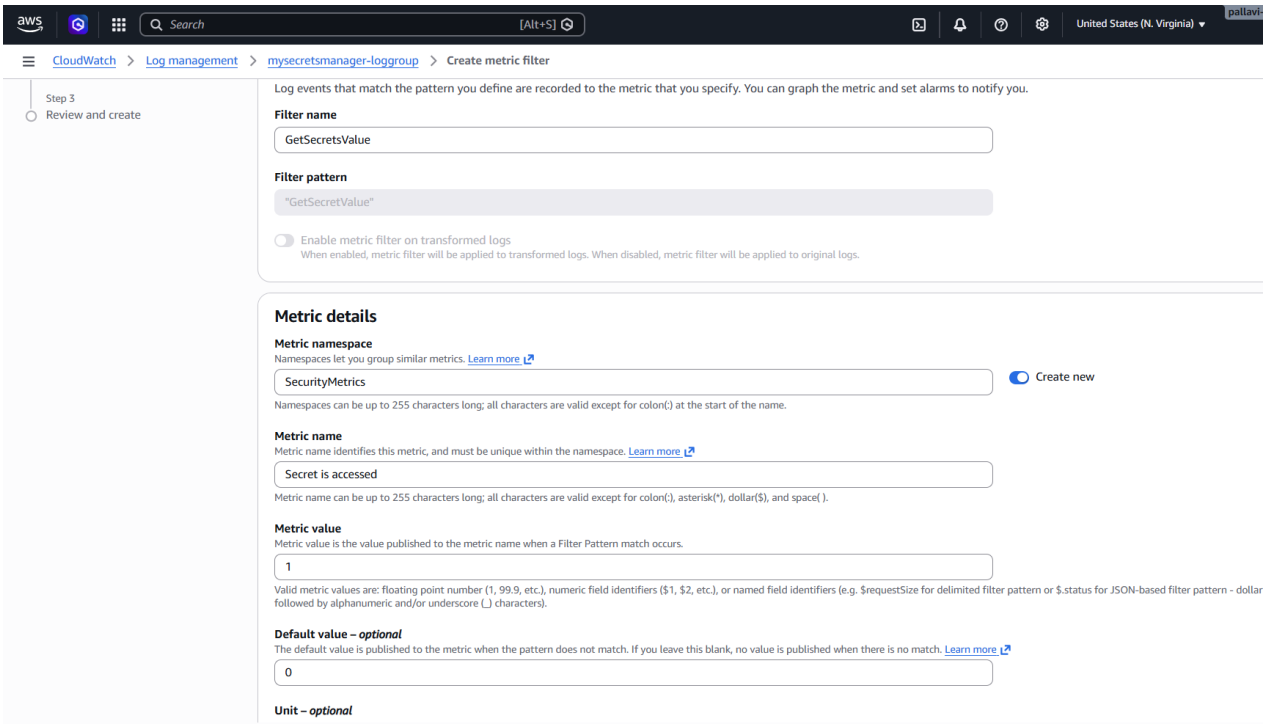

Fig. 4: Metric Filter pattern

CloudWatch Alarm

The threshold setting in the CloudWatch alarm triggers an alert the moment our secret is touched.

I set:

1. The Value (Threshold = 1): I have set the threshold value to 1. This means the alarm is counting occurrences. It looks for a minimum of one single event to take action.
2. The Logic (Greater/Equal): By choosing Greater/Equal (\(\ge \)), we are telling CloudWatch: "If this event happens 1 time, or 5 times, or 100 times, trigger the alarm." It will ignore the number 0 (no access), but anything 1 or higher fires the alert.

3. The Combined Result: Because our metric is tracking a sensitive action (SecretIsAccessed), this threshold turns our alarm into a **Zero-Trust Security Alert**.
It means:
0 accesses = Normal state (Alarm is OK).
1+ accesses = Breach state (Alarm immediately turns to ALARM).

An SNS (Simple Notification Service) topic is a logical access point and communication channel used to group destinations and broadcast messages to multiple subscribers simultaneously.

Key Characteristics
Pub/Sub Model: It acts as a centralized "publisher" that sends a single message out to many "subscribers" instantly.

Decoupled Architecture: The system sending the alert (like your CloudWatch alarm) does not need to know who is receiving it; it just sends it to the topic.

Diverse Destinations: A single topic can deliver your alert to multiple formats at once, including Email, SMS, AWS Lambda functions, HTTPS webhooks (like Slack or Teams), and SQS queues.

How It Fits our Secret Alarm:
When our “SecretIsAccessed” threshold is breached, CloudWatch sends a notification to our SNS topic. The SNS topic then instantly routes that alert to my email.

AWS requires email confirmation because they want to make sure it's really you asking for these alerts. This helps prevent intrusion.

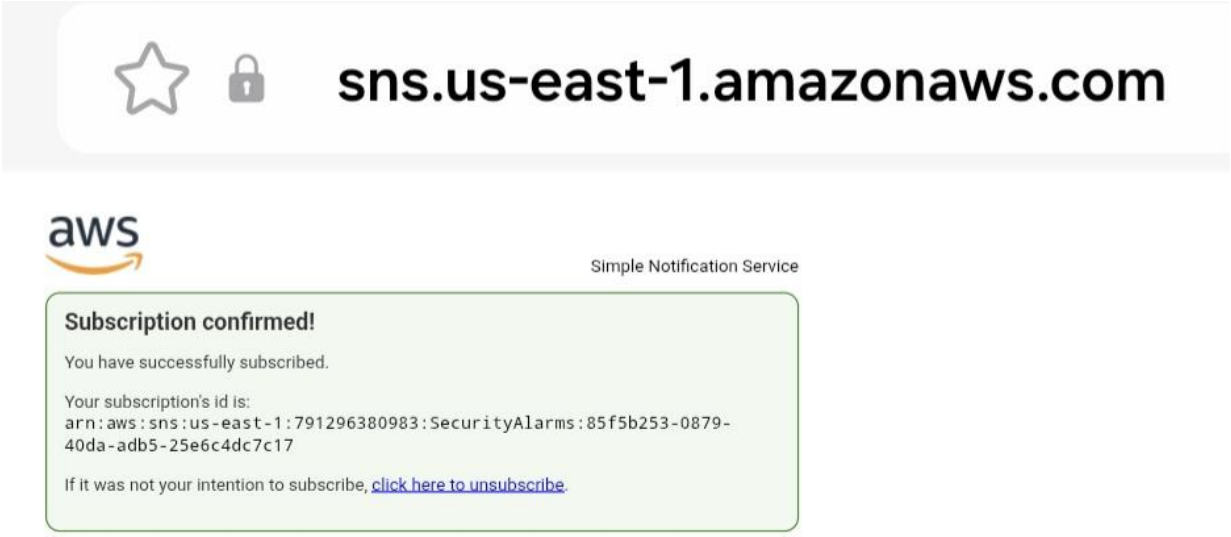

Fig. 5: Subscription confirmed AWS SNS

Troubleshooting Notification Errors

When troubleshooting the notification issues, I went through each of this consoles for troubleshooting:
CloudTrail
Log Delivery
Metric Filter
Alarm Configuration
SNS Subscription

I initially didn't receive an email before because the static was set to "Average". The key solution was to set it to "Sum" and 1 minute from 5 minutes.

Success!

To validate Secrets Manager and retrieved the Secret. I checked Cloudwatch if the Alarm went off. I receive the email notification when the Alarm went off.

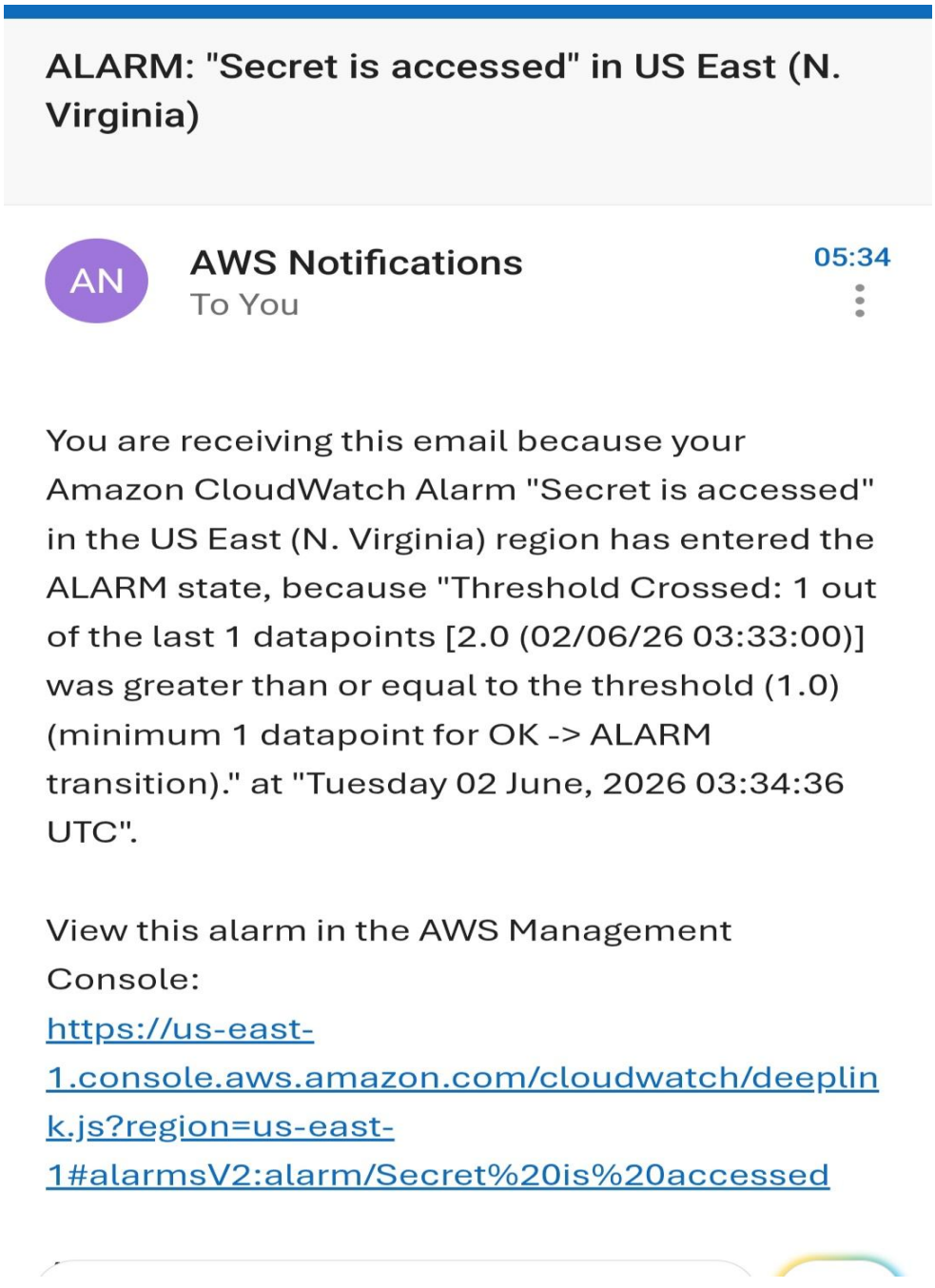

Fig. 6: Alarm notification email